Dev2 정적분석 — A커머스(e-commerce) 전용 커스텀 검증 규칙

> **대상 에이전트**: `static_analysis` (Dev2) **적용 범위**: PR diff에 포함된 변경 파일 (`.py` 우선, 일부 규칙은 전 언어) **표준 도구와의 관계**: pylint / radon / eslint / roslyn / htmlhint / stylelint 가 잡지 못하는 **커머스 도메인 정합성·아키텍처·컨벤션** 위반을 보완한다. **구현**: `dev2/tools/python/custom_static_tool.py` (`run_custom_static`, AST 기반)

---

1. 왜 커스텀 규칙이 필요한가

A커머스는 **주문·결제·정산**이 핵심인 온라인 쇼핑 플랫폼이다. 표준 정적분석 도구는 "언어 일반" 품질(미사용 변수, PEP8, 순환복잡도)만 본다. 하지만 커머스 도메인에는 **금액 정확성, 클라이언트 가격 신뢰 경계, 결제 멱등성** 같은 고유 제약이 있고, 이를 어겨도 표준 린터는 통과시킨다. 아래 규칙은 그 공백을 메운다.

표준 도구가 보는 것	A커머스 커스텀 규칙이 보는 것
문법 오류, 미사용 변수, PEP8	금액을 float로 다룸(부동소수점 오차)
순환복잡도 수치	클라이언트가 보낸 결제 금액을 서버 재계산 없이 신뢰
타입 주석 존재 여부	결제 요청 멱등성 키 누락(중복 결제)
—	레이어 의존성 역전, Repository 우회, PG 키 하드코딩

---

2. 규칙 ID 체계

```
ASA-NNN  = A社 Static Analysis 커스텀 규칙
```

- 표준 도구 유래 ID(`SA-E0602`, `SA-COMPLEXITY` 등)와 네임스페이스가 겹치지 않는다.
- Output Contract `Issue.rule_id` 에 그대로 기록한다 (예: `"rule_id": "ASA-001"`).

severity 매핑 기준 (기존 도구 매핑과 일관)

severity	의미	기준 예시
Critical	머지 시 시스템/계약 파손	레이어 역방향 import
Major	정산·결제 시 장애 유발	금액 float, 클라이언트 금액 신뢰, 멱등성 누락
Minor	권고·일관성	PG 키/URL 하드코딩

> `issue_type` 은 `"Bug"` 또는 `"Code Smell"` 로 기록 (보안은 별도 문서 참조).

---

3. 커스텀 규칙 목록

ASA-001 — 통화/금액 float 사용 (Decimal 강제)

- **severity**: Major · **issue_type**: Bug · **적용**: `.py`
- **근거**: 부동소수점은 `0.1 + 0.2 != 0.3` — 결제·정산 금액에 오차가 누적된다.
- **탐지 패턴**: `price`/`amount`/`total`/`discount`/`fee` 등 금액 이름 변수에 float 리터럴(`19.99`)이나 `float(...)` 캐스팅을 사용. `: float` 어노테이션 포함.
- **나쁜 예 / 좋은 예**

```
# BAD
total_amount = 19.99
# GOOD
total_amount = Decimal("19.99")   # 또는 정수(원 단위)
```

- **suggestion**: "금액·통화는 `decimal.Decimal` 또는 정수(최소 화폐단위)로 다루세요."

ASA-002 — 클라이언트 전달 금액 신뢰

- **severity**: Major · **issue_type**: Bug · **적용**: `.py`
- **근거**: 클라이언트가 보낸 가격/금액을 그대로 쓰면 **가격 조작 결제**가 가능하다.
- **탐지 패턴**: 금액 이름 변수에 `request`/`body`/`data`/`params` 등에서 파생된 값(`request.json["amount"]`, `data.get("price")`)을 직접 대입.
- **suggestion**: "결제 금액은 서버에서 상품 가격을 재조회해 재계산하세요."

ASA-003 — Clean Architecture 레이어 의존성 역전

- **severity**: Critical · **issue_type**: Bug · **적용**: `.py` (서비스/도메인 레이어)
- **탐지 패턴**: 도메인/서비스(`services/`, `domain/`, `usecases/`, `*_service.py`)에서 프레임워크(`fastapi`/`flask`/`django`)·드라이버(`psycopg`/`pymysql`/`redis`)를 직접 import.
- **suggestion**: "의존성은 안쪽(도메인)을 향해야 합니다. Repository/인터페이스를 통해 접근하세요."

ASA-004 — Repository 패턴 우회 (서비스 코드 내 직접 SQL/ORM)

- **severity**: Major · **issue_type**: Code Smell · **적용**: `.py` (서비스/도메인 레이어)
- **탐지 패턴**: 서비스 함수 본문에 SQL 문자열(`SELECT`/`INSERT`/...)이나 `.execute(`/`session.query(` 가 직접 등장.
- **suggestion**: "SQL/ORM 호출을 Repository 계층으로 옮기세요. 서비스는 비즈니스 로직만."

ASA-005 — 순환복잡도 사내 강화 임계

- **severity**: Major · **issue_type**: Code Smell · **적용**: `.py`
- **근거**: `radon`(표준 cc>10) 보완 — A커머스 기준은 **cc>8 또는 중첩 깊이≥4**. 주문 상태 전이·할인 계산 분기가 복잡해지기 쉬워 임계를 강화한다.
- **suggestion**: "함수를 8 이하로 분리하세요. 가드절(early return)로 중첩을 줄이세요."

ASA-006 — 에러 삼킴 금지 (결제/주문 예외)

- **severity**: Major · **issue_type**: Bug · **적용**: `.py`
- **탐지 패턴**: `except Exception:` 블록이 `pass`/`...` 이거나 로그·전파가 전혀 없음.

- **근거**: 결제·재고 차감 실패가 묻히면 정합성(돈/재고)이 깨진다.
- **suggestion**: "예외는 로그 기록 후 상위로 전파하거나, 보상 트랜잭션/롤백을 수행하세요."

ASA-007 — 외부 연동 키/URL 하드코딩

- **severity**: Minor · **issue_type**: Code Smell · **적용**: `.py`
- **탐지 패턴**: `*_URL`/`*_KEY`/`*_SECRET`/`USE_MOCK*` 가 `os.getenv` 없이 리터럴로 고정. (PG/배송/SMS 연동 주소·키)
- **suggestion**: `os.getenv("PG_API_URL", "https://mock-pg.local")` 패턴을 쓰세요.

ASA-008 — 결제 멱등성 키 누락

- **severity**: Major · **issue_type**: Bug · **적용**: `.py`
- **근거**: 네트워크 재시도/더블클릭 시 **중복 결제**가 발생한다.
- **탐지 패턴**: `charge`/`capture`/`create_payment`/`request_payment` 등 결제 호출에 `idempotency_key=`(또는 `idempotency=`) 인자가 없음.
- **suggestion**: "결제 요청에 `idempotency_key=주문ID 기반 고유값`을 전달해 중복 결제를 방지하세요."

---

4. 도구 연동 방법

1. `dev2/tools/python/custom_static_tool.py` — `run_custom_static(files) -> list[dict]` (Python `ast` 기반 사내 룰 러너). 각 위반을 §2 severity로 매핑, `rule_id`는 `ASA-NNN`. 파싱/읽기 실패 시 **빈 리스트 반환** (CLAUDE.md §12 — 파이프라인 차단 금지).
2. `tools/router.py` `LANGUAGE_TOOL_MAP[".py"]` 정적분석 목록에 `"custom_static"` 추가.
3. `nodes/run_tools.py` `_run_python()` 에서 `static_parts` 로 합류 (pylint·radon과 동일 분류).
4. 결과는 `static_raw` → `enriched` → `final_output` 순으로 흘러 `AgentOutput(agent="static_analysis")` 에 포함된다.

> **계약 불변식**: 커스텀 규칙도 반드시 `schema.Issue` 9개 필수 필드를 채운다.

---

5. 요약 표

ID	규칙	severity	issue_type
ASA-001	통화/금액 float 사용	Major	Bug
ASA-002	클라이언트 전달 금액 신뢰	Major	Bug
ASA-003	레이어 의존성 역전	Critical	Bug
ASA-004	Repository 패턴 우회	Major	Code Smell
ASA-005	순환복잡도 강화 임계(cc>8)	Major	Code Smell
ASA-006	에러 삼킴 금지	Major	Bug
ASA-007	외부 연동 키/URL 하드코딩	Minor	Code Smell
ASA-008	결제 멱등성 키 누락	Major	Bug